Unauthenticated access to third-party order data on the checkout API

Field	Value
Target	Aghanim (aghanim.com)
Asset	api.aghanim.com (in scope: policy section 3.1.2)
Endpoint	GET /checkout/v1/orders/{order_id}
Severity	High (7.5)
CVSS v3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CWE	CWE-306 Missing Authentication for Critical Function / CWE-200 Exposure of Sensitive Information
Researcher	Mr Fz <fzsusanto@gmail.com>
Found	2026-10-27 from Medan, Indonesia, Asia/Jakarta, 104.28.194.248

Summary

The checkout front-end can talk to two API generations: the current one at **pay-api.aghanim.com/order/v1** and a legacy sibling at **api.aghanim.com/checkout/v1**. The order object is the same on both, but the legacy sibling exposes a method the current one does not.

It answers 200 to an unauthenticated **GET /v1/orders/{order_id}** and returns the complete order object, including the customer IP address, the browser User-Agent, the in-game player identifier and the player display name. On the same object the current-generation API returns **405 Method Not Allowed**. The two hosts disagree about who may read an order, and the legacy path is the permissive one.

Affected request

```
GET /checkout/v1/orders/{order_id} HTTP/1.1
Host: api.aghanim.com

No Authorization header, no cookie, no API key.
```

Response: **HTTP/1.1 200 OK**, application/json, 6192 bytes for the order examined. The body carries 68 top-level keys. The sensitive ones are ip_address, user_agent, player_id, player_info.name, user_id and datahouse_user_id.

Steps to reproduce

```
STEP 1 - take an order id that is already published. The checkout URL is the
player-facing link, so it appears in search results, tickets and chats.
The one used here is indexed publicly as:

pay.aghanim.com/en/order/ord_eFnCYslSTNAhPSCm

Nothing was guessed and nothing was enumerated.
```

```
STEP 2 - call the legacy API with no credentials:

curl -s -i https://api.aghanim.com/checkout/v1/orders/ord_eFnCYslSTNAhPSCm

-> 200 OK with ip_address, user_agent, player_id, player_info.name in the body
```

```
STEP 3 - the same id on the current generation:

curl -s -i https://pay-api.aghanim.com/order/v1/orders/ord_eFnCYslSTNAhPSCm

-> 405 Method Not Allowed (this is the inconsistency)
```

```
STEP 4 - control, to show 200 is object-specific and not a catch-all:

curl -s -i https://api.aghanim.com/checkout/v1/orders/ord_AAAAAAAAAAAAAAA

-> 404 Not Found
```

Reproduced three times, 8 to 10 seconds apart, identical each time: HTTP 200 with ip_address, user_agent and player_id present on every attempt.

Evidence

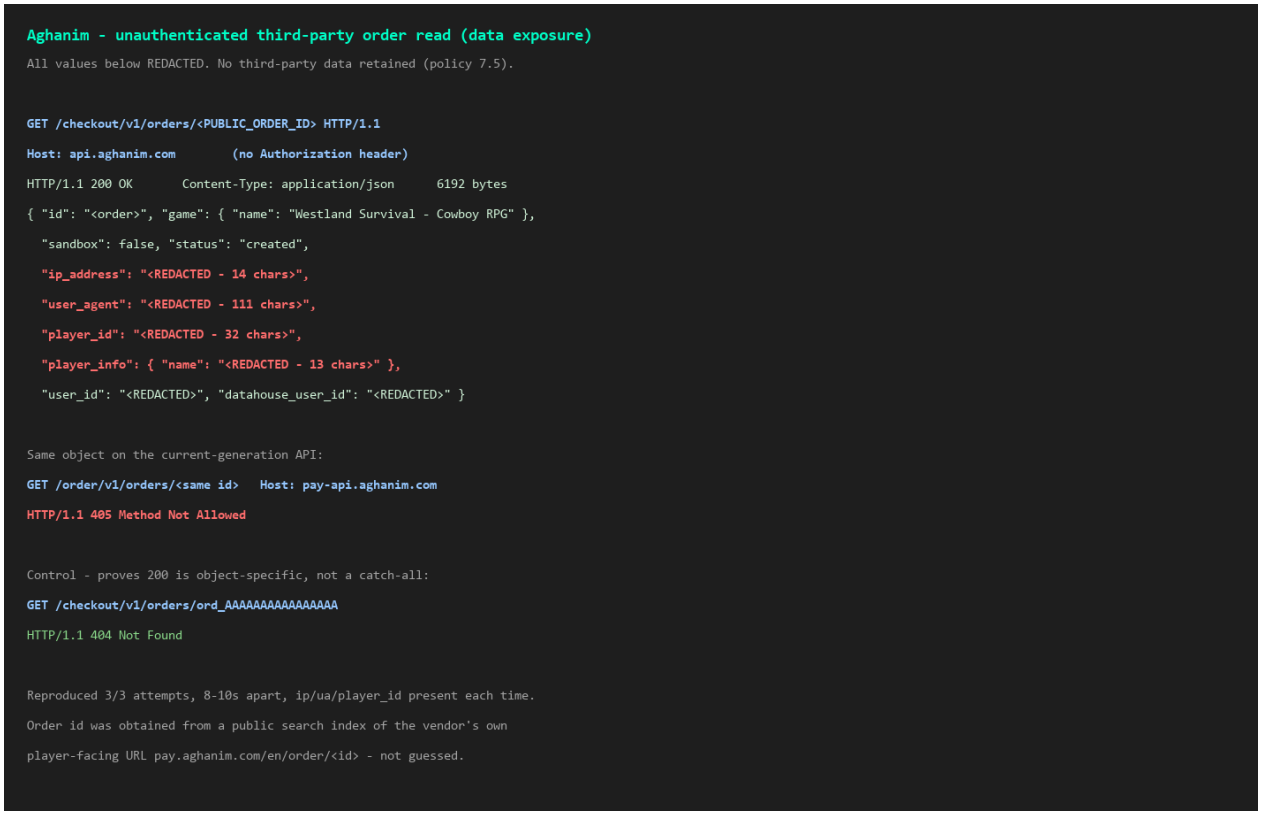


Figure 1. The four requests. Every value belonging to the customer is redacted here; no third-party data was written to disk at any point.

Impact

The order used belongs to a live, non-sandbox game (Westland Survival - Cowboy RPG) and the record holds a real customer IP address, a 111-character User-Agent string, and the in-game player identifier and display name. Anyone holding the order link can turn it into that customer profile.

The practical use is account recovery against the game operator. Support staff ask a player to confirm identity, and player_id plus display name plus IP plus device fingerprint is what that check relies on. It also links one person across every game on the platform through datahouse_user_id. I did not attempt any recovery and I am not claiming account takeover: what is proved here is the disclosure.

Why policy 4.2.14 does not exclude this

Section 4.2.14 excludes findings that depend on guessing or enumerating resource identifiers. This one does not. The order id came from a public search result pointing at the vendor own player-facing URL, so it is published, not guessed. No enumeration was performed and no second order was read. The defect is the missing authorization check, not the shape of the identifier.

What I proved, and what I did not

Claim	Status
Order readable with no credentials	Proved, 3 of 3 attempts, 200 each
Body contains IP, User-Agent, player identity	Proved, present in every response
Current-generation API refuses same object	Proved, 405 Method Not Allowed
Identifier is published, not guessed	Proved, public search index of vendor URL
Affects live, non-sandbox orders	Proved, sandbox=false on this order
Account takeover via support recovery	NOT proved, argued only
Bulk enumeration of many orders	NOT attempted, not needed

Suggested fix

Put the legacy **/checkout/v1/orders/{id}** route behind the authorization the current generation uses, or retire it. If a guest read is genuinely needed for checkout, return only what the page renders (item, amount, currency, status) and keep ip_address, user_agent and the player identity server-side. The same rule on player_info.name would remove the display name from an anonymous read as well.

Programme compliance

Requirement (policy v2026-08-24)	How this report meets it
Scope, section 3.1.2 host list	api.aghanim.com is listed
Section 5.3.5 PII exposure	The category reported here
Section 7.1 use own accounts	No account used, none created
Section 7.3 throttle tools	Four manual requests, no scanning
Section 7.5 sensitive data	Stopped on sight, retained nothing, values redacted
Section 7.6 no side effects	GET requests only, nothing modified
Section 8.2 report contents	Description, steps, PoC, impact, fix
Section 13 no public disclosure	Not disclosed anywhere

Contact: Mr Fz, fzsusanto@gmail.com